Threat Intelligence Report: Scattered Spider (Extended)

TLP:CLEAR (open-source reporting) | **Date:** October 22, 2026 | **Prepared by:** OKUNNUWA JOSHUA GODWIN

Aliases: UNC3944, Octo Tempest, Storm-0875, 0ktapus, Muddled Libra, Scatter Swine | **MITRE ATT&CK:** G1015 | **Motivation:** Financial (data theft, extortion, ransomware)

This is the extended version of my two-page brief. The short version gives the main points. This one gives the evidence, the full ATT&CK mapping and the reasoning behind my conclusions.

1. Bottom Line

Scattered Spider doesn't need much malware. They call the IT help desk, pose as an employee, and get a password and MFA reset. After that they log in like anyone else and use legitimate admin tools, which is why they are so hard to catch. Since 2023 this has worked on casinos, retailers, insurers, airlines, healthcare providers and transit.

In 2026 the group took real damage. Core members were convicted or sentenced in the US and UK, and the UK National Crime Agency (NCA) said its case had effectively halted the group's activity. I still wouldn't relax. The NCA itself warned that other criminals may keep using the name, and the method costs almost nothing to copy.

2. Scope and Method

Everything here comes from open sources: the CISA and FBI joint advisory AA23-320A, MITRE ATT&CK group G1015, Department of Justice releases, NCA statements, vendor research from Microsoft, CrowdStrike, Picus and others, and news reporting. I did not use any private or paid intelligence.

I rate my confidence in three levels. **High** means several independent government or vendor sources agree. **Moderate** means credible reporting from one or two sources. **Low** means a claim I could not confirm, such as something posted by the group itself. One warning from researchers at Flare is worth repeating: a help desk call alone does not prove an incident was Scattered Spider. Attribution needs more evidence than that.

3. Actor Profile

Scattered Spider is a loose group of mostly young, native English speakers. It came out of The Com, a wider cybercrime community, and has been active since at least 2022. Its members have been described as teenagers and people in their twenties, and the cases from 2026 bear that out. Jubair was 20 and Flowers 18 when they were sentenced.

It isn't a tight organization with fixed roles. People drift between crews, share tools and sell access. That is why researchers argue about where one group ends and the next begins.

The early work was SMS phishing. In 2022 the group sent tens of thousands of text messages that led to intrusions at companies including Twilio, LastPass, DoorDash and Mailchimp. Okta's customers were hit in the same campaign, which is where the name 0ktapus comes from. From there the group moved to SIM swapping, crypto theft and, from 2023, extortion and ransomware.

CISA and the FBI say the group targets large companies and the IT help desks those companies contract out to (AA23-320A). Members often hand access to ransomware partners rather than encrypting networks themselves. The partners named in reporting are BlackCat/ALPHV (2023), RansomHub and Qilin, and DragonForce (2025).

Scale. A DOJ complaint filed in July 2026 against Peter Stokes says the group has been involved in more than 100 network intrusions and more than $100 million in ransom payments. A separate DOJ complaint against Thalha Jubair put the ransom figure at $115 million. These are allegations, and the people named have not all been convicted.

4. Timeline of Key Incidents and Cases

Date	Event	Why it matters
2022	SMS phishing campaign hits Twilio, LastPass, DoorDash, Mailchimp and Okta customers	The group's first big wave, and where 0ktapus comes from
Sept 2023	MGM Resorts and Caesars	Help desk social engineering caused outages and data theft at two of the largest casino operators
Nov 2023	CISA and FBI publish AA23-320A	First joint advisory on the group, later updated on July 29, 2025

Date	Event	Why it matters
Aug 2024	Transport for London	Cost about £29 million; the pair partly got in using purchased credentials to reset staff 2FA
Nov 2024	US charges five members	Early sign that law enforcement had found the core
Apr 2025	Marks & Spencer, plus similar attacks on Co-op and Harrods	DragonForce ransomware; M&S estimated about £300 million off operating profit
Mid 2025	Insurance and aviation campaign	Aflac and others hit in a sector-by-sector run
Aug 2025	Noah Urban sentenced in the US	10 years in prison and $13 million restitution
Sept 2025	Jaguar Land Rover	Attributed to the merged Scattered Lapsus$ Hunters collective; reported £196 million in direct costs and five weeks of lost UK production
Sept 2025	Jubair and Flowers arrested in the UK	Start of the case that later ended in prison terms
Apr 17, 2026	Tyler Buchanan pleads guilty in California	Wire fraud conspiracy and aggravated identity theft; at least $8 million in crypto stolen
Jun 22, 2026	Jubair and Flowers plead guilty at Woolwich Crown Court	They changed their pleas on the first day of trial
Jul 1, 2026	Peter Stokes extradited from Finland to the US	Charged in the Northern District of Illinois
Jul 16, 2026	Jubair and Flowers each sentenced to 5 years 6 months	NCA says the group's criminal activity was effectively halted
Oct 2026	Microsoft reports Octo Tempest changing its entry route	Some intrusions now start on-premises before moving to the cloud

A note on the casino attacks. They are the most famous incidents, but they are not the ones Buchanan pleaded guilty to. His plea covers the 2022 phishing campaign and the crypto thefts. News articles often blur this, so I kept the two apart.

5. Targets

- **Casinos and hospitality:** MGM Resorts, Caesars and other Las Vegas brands.
- **Retail:** Marks & Spencer, Co-op and Harrods in the UK.
- **Insurance and aviation:** Aflac and, per press reporting, WestJet.
- **Technology and telecom:** Twilio, Okta customers, LastPass and others in 2022.
- **Healthcare:** SSM Health Care and Sutter Health, both confirmed in Flowers' guilty plea.
- **Transport:** Transport for London.
- **Manufacturing:** Jaguar Land Rover, through the merged collective.

The group tends to pick one sector and hit as many companies in it as it can over a short stretch. Flashpoint described this as a wave-like pattern. It's a useful hint for defenders: when a peer in your industry is hit, expect your help desk to get the next call.

6. How They Operate

Research. They collect names, job titles, phone numbers and help desk procedures from professional profiles, company websites, business-to-business sites and breached data. CISA says the group searches business sites to learn what role a person holds in the target (T1594).

Getting in. The early campaigns relied on broad phishing. CISA says the group now runs more targeted, multi-layered spearphishing and voice phishing. The usual script is a call to the help desk from someone who sounds like an employee, asking for a password reset or for MFA to be moved to a new device. They also send SMS links to lookalike login pages, swap SIM cards, spam MFA push prompts and use adversary-in-the-middle kits to steal session tokens. In the TfL case, the pair bought partial staff credentials on criminal forums and used them to reset 2FA on employee accounts. It took several attempts.

Staying in. Once inside, one of the first moves is to remove the real MFA device from the account, enroll one the attacker controls, and delete the alerts that would warn the victim. CrowdStrike says it has seen data theft begin in under an hour in some cases. The group also creates new accounts and installs legitimate remote access software such as Atera, plus tunneling tools that CISA lists in its advisory.

Hiding. They disable security tools and blend in with normal admin activity. The group has also been seen joining incident response calls and chats to watch what defenders are doing.

Taking the data. They look for cloud and virtualization admin accounts, read internal chats and wikis, stage data, and send it to cloud storage. CISA names MEGA.NZ and US-based data centers as exfiltration destinations.

Getting paid. Money comes from extortion and, when encryption is the goal, ransomware on VMware ESXi hosts. Demands arrive over Telegram, Signal or Tor, according to press coverage.

A recent shift. Microsoft's October 2026 reporting says Octo Tempest used to use cloud identity privileges to reach on-premises systems. More recent cases hit on-premises accounts and infrastructure first, then move to the cloud. If your detections assume the old order, they may fire late.

7. MITRE ATT&CK Mapping

I built this from MITRE ATT&CK G1015 and CISA AA23-320A (ATT&CK v17). Each row ties to behavior described in those sources. Check the IDs against attack.mitre.org if you are using a newer ATT&CK version.

Tactic	Technique	Observed behavior
Reconnaissance	T1594 Search Victim-Owned Websites	Looking up staff roles on business sites, as cited in AA23-320A
Reconnaissance	T1598.004 Phishing for Information: Spearphishing Voice	Calling help desks to collect account details
Reconnaissance	T1589.001 Gather Victim Identity Info: Credentials	SMS phishing to steal credentials
Resource Development	T1583.001 Acquire Infrastructure: Domains	Lookalike corporate login portals
Initial Access	T1566.002 Phishing: Spearphishing Link	Phishing kits and fake SSO pages
Initial Access	T1566.004 Phishing: Spearphishing Voice	Impersonating staff to reset credentials

Tactic	Technique	Observed behavior
Initial Access	T1451 SIM Card Swap	Taking over phone numbers to receive MFA codes
Initial Access	T1078 Valid Accounts	Logging in with stolen or reset credentials
Credential Access	T1621 MFA Request Generation	Repeated push prompts until approved
Credential Access	T1539 Steal Web Session Cookie	Token theft to skip MFA
Persistence	T1136 Create Account	New identities inside the victim network
Persistence	T1556.006 Modify Authentication Process: MFA	Enrolling attacker-controlled MFA devices
Defense Evasion	T1562.001 Impair Defenses: Disable or Modify Tools	Uninstalling or disabling security software
Defense Evasion	T1656 Impersonation	Posing as employees and IT staff
Command and Control	T1219 Remote Access Software	Legitimate remote tools used as backdoors
Discovery	T1087 Account Discovery	Finding vSphere and cloud admin accounts
Discovery	T1217 Browser Information Discovery	Browser history pulled by infostealers
Collection	T1074 Data Staged	Central staging before exfiltration
Exfiltration	T1567.002 Exfiltration to Cloud Storage	MEGA.NZ and other cloud services
Impact	T1486 Data Encrypted for Impact	Ransomware on ESXi servers, via affiliates (BlackCat/ALPHV, DragonForce)
Impact	T1657 Financial Theft	Extortion, ransom payments and crypto theft

8. Tools and Partners

- **Remote access:** Atera and other legitimate remote tools and tunneling software.
- **Credential theft:** Raccoon Stealer and phishing kits, including adversary-in-the-middle kits.
- **Malware:** Spectre RAT, with an updated version seen in early 2025.
- **Ransomware partners:** BlackCat/ALPHV, RansomHub, Qilin and DragonForce.
- **Storage and contact:** MEGA.NZ for exfiltration, Telegram for extortion and internal chat.

9. Related Groups and Attribution Problems

The names around this group are messy, and I think that matters for anyone reporting on it.

- **Scattered Lapsus$ Hunters.** Since 2025 the group has worked with ShinyHunters and Lapsus$. Researchers have tied that collective to Salesforce-related data theft and a leak site that listed 39 victims. The reporting on its size is mixed, and the claim of 1.5 billion stolen records comes from the group itself, so I treat it as low confidence.
- **Cordial Spider and Snarky Spider.** CrowdStrike says these two newer groups have been running data theft and extortion campaigns against US organizations since at least October 2025, using account recovery fraud. I read them as the next generation using the same playbook, not necessarily the same people.
- **ShinyHunters.** Still breaching large companies. In 2026 it continued to operate while Scattered Spider members were being jailed.

Two cautions. First, the NCA said others may reuse the Scattered Spider brand. A group claiming the name is not proof of the original crew. Second, the Flare point from earlier applies again: the help desk method is shared, so the method alone isn't proof of attribution.

10. Current Status and My Assessment

What changed in 2026. Urban was sentenced in 2025. In 2026, Buchanan pleaded guilty in the US, Jubair and Flowers were sentenced in the UK, and Stokes was extradited from Finland. Buchanan's sentencing was set for August 21, 2026. I could not find the outcome in my sources, so I haven't reported it.

What didn't change. The NCA said its action effectively halted the group's criminal activity, and SecurityWeek noted that no new attacks had been announced in recent months. But ShinyHunters kept going, new groups appeared, and Microsoft and Flare were still describing active help desk campaigns this month.

My view. The original crew is badly damaged, and I think that's a fair reading of the NCA statement. The threat is not. Help desk fraud costs almost nothing, works against large companies, and doesn't need skill with exploits. I expect the same techniques to keep showing up under new names.

Confidence. High on the TTPs, because government and vendor sources agree. Moderate on who is currently active, because the group is fluid and public claims are unreliable.

11. Detection and Defense

Detect

- Alert when a password or MFA reset is followed by a new device enrollment within hours (T1556.006, T1078).
- Watch for new remote access tools such as Atera, installed outside change windows (T1219).
- Flag impossible-travel or new-location sign-ins right after a help desk ticket.
- Look for MFA devices being removed and alert emails being deleted on the same account.
- Monitor for security agent removal and bulk downloads from cloud storage (T1562.001, T1567.002).
- Track vSphere admin logins and new ESXi activity.
- Check on-premises accounts and infrastructure for early signs, not just cloud identity logs, given Microsoft's latest reporting.

Prevent

- Use phishing-resistant MFA (FIDO2 keys) for staff and admins, and move away from SMS codes.
- Make help desk staff verify identity with a call-back to a known number or manager approval before any reset. No exceptions. The NCSC advised UK organizations in 2025 to review password reset policies for help desks and tighten authentication for privileged accounts.
- Restrict which remote access tools can run, using application allowlisting.

- Keep offline, tested backups, especially for ESXi hosts.
- Check how your outsourced help desk handles resets. The M&S investigation pointed at a third-party supplier, though that supplier said its own systems were not compromised.

Respond

- Pre-plan out-of-band communication so attackers cannot watch your response channels.
- Assume a reset call that went wrong means the account is compromised, and review every session and device on it.

12. Limits of This Report

- Open sources only. I had no access to victim telemetry or private intelligence feeds.
- Some figures come from press reporting and vendor blogs, such as the JLR costs, the Aflac numbers and the Salesforce claims. They are labeled as reported, not confirmed.
- Court cases are still moving. Charges in the US are allegations until proven.
- Buchanan's sentencing outcome was not available in my sources.
- ATT&CK IDs follow v17. Later versions may renumber some techniques.

13. Sources

1. CISA/FBI et al., Joint Advisory AA23-320A, Scattered Spider (published Nov 2023, updated Jul 2025): https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a
2. MITRE ATT&CK, Group G1015 Scattered Spider: https://attack.mitre.org/groups/G1015/
3. US Department of Justice, Alleged Scattered Spider member arrested in Finland and extradited (Jul 1, 2026): https://www.justice.gov/opa/pr/alleged-member-criminal-cyber-hacking-group-scattered-spider-arrested-finland-and-extradited
4. SecurityWeek, Two Scattered Spider Hackers Sentenced to Jail in UK (Jul 16, 2026): https://www.securityweek.com/two-scattered-spider-hackers-sentenced-to-jail-in-uk/
5. TechCrunch, UK cops say arrest of two young hackers disrupted the operations of an infamous hacking group (Jul 16, 2026): https://techcrunch.com/2026/07/16/uk-cops-say-arrest-of-two-young-hackers-disrupted-the-operations-of-an-infamous-hacking-group/

6. The Register, Brit Scattered Spider duo handed prison terms over Transport for London attack (Jul 16, 2026): https://www.theregister.com/cyber-crime/2026/07/16/brit-scattered-spider-duo-handed-tickets-to-prison-over-transport-for-london-attack/5272446
7. The Record, Two Scattered Spider members plead guilty over cyberattack that crippled London transit (Jun 2026): https://therecord.media/guilty-plea-tfl-cyberattack-scattered-spider-members
8. CyberScoop, Scottish man pleads guilty to attack spree that created Scattered Spider's notoriety (Apr 2026): https://cyberscoop.com/the-com-scattered-spider-hacker-tyler-robert-buchanan-guilty-plea/
9. Efani, Tyler Buchanan Sentencing: Inside the $8 Million Phishing and SIM-Swap Operation: https://www.efani.com/blog/tyler-buchanan-sentencing-sim-swap-case
10. Paubox, Scattered Spider members plead guilty to US healthcare breaches (Jul 2026): https://www.paubox.com/blog/scattered-spider-members-plead-guilty-to-us-healthcare-breaches
11. Infosecurity Magazine, Microsoft Exposes Scattered Spider's Latest Tactics (Oct 2026): https://www.infosecurity-magazine.com/news/microsoft-exposes-scattered/
12. Proof, The New Generation of Scattered Spider Is Turning Account Recovery Into a Seven-Figure Business (May 2026, updated Jul 2026): https://www.proof.com/blog/turning-account-recovery-into-a-seven-figure-business
13. Cyber Security News, Scattered Spider Hackers Exploit Help Desk Calls to Bypass MFA (Oct 21, 2026): https://cybersecuritynews.com/scattered-spider-hackers/
14. Retail Systems, M&S cyber attack to cost £300m with disruption until July (May 2025): https://retail-systems.com/rs/MS_Cyber_Attack_To_Cost_300m_With_Disruption_Until_July.php
15. Digit, M&S Restores Click-and-Collect Service After Cyber-attack: https://www.digit.fyi/?p=122575
16. Breached.company, Scattered Spider incident tracker: https://breached.company/threat-actors/scattered-spider/
17. Brandefense, Scattered Spider threat group profile (updated Oct 9, 2026): https://brandefense.io/knowledge-hub/apt-groups/scattered-spider/
18. DarkOwl, Threat Actor Spotlight: Scattered Lapsus$ Hunters (Jan 2026): https://www.darkowl.com/blog-content/threat-actor-spotlight-scattered-lapsus-hunters/

19. Picus Security, Tracking Scattered Spider Through Identity Attacks and Token Theft (Jul 2025): https://www.picussecurity.com/resource/blog/tracking-scattered-spider-through-identity-attacks-and-token-theft
20. KrebsOnSecurity, Scattered Spider coverage: https://krebsonsecurity.com/tag/scattered-spider/